

FastAPI Authentication, CORS, Headers, and Credentials Notes

Token Type: Bearer

`token_type='bearer'` tells the client how to use the access token. After login, the client sends: Authorization: Bearer The word 'Bearer' is part of the standard format for JWT authentication.

allow_headers

`allow_headers` controls which HTTP headers the browser is allowed to send in cross-origin requests. Examples of headers: - Authorization - Content-Type - Accept - X-API-Key
`allow_headers=['*']` means all headers are allowed.

allow_credentials

`allow_credentials` controls whether authentication-related information can be included in cross-origin requests. Examples: - Cookies - Session IDs - Authentication credentials
`allow_credentials=True` means the browser is allowed to send this authentication information to the backend.

Difference Between allow_headers and allow_credentials

`allow_headers`: - Controls WHICH headers can be sent. - Example: Authorization, Content-Type, X-API-Key. `allow_credentials`: - Controls WHETHER authentication information can be sent. - Example: cookies, sessions, login credentials. Simple analogy: - Headers = documents you carry. - Credentials = proof of identity.

CORS Overview

CORS (Cross-Origin Resource Sharing) is a browser security mechanism. Example: Frontend: `http://localhost:3000` Backend: `http://localhost:8000` Because these are different origins, the browser checks the backend's CORS policy before allowing requests.